

Cybersecurity Daily Newsletter

Vol. 001 | 2026-05-21 07:00 WIB

Top 5 Highlights

- Drupal admins rushing to patch maximum severity SQL injection vulnerability
- WantToCry ransomware evades detection through SMB abuse, remote encryption
- Ukraine identifies infostealer operator tied to 28,000 stolen accounts
- APIs under pressure: How AI is rewriting the rules of enterprise security
- VU#980487: Local privilege escalation in Linux Kernel (Dirty Frag)

Threat Intelligence (10)

01. Ukraine identifies infostealer operator tied to 28,000 stolen accounts

The Ukrainian cyberpolice, working in conjunction with U.S. law enforcement, has identified an 18-year-old man from Odesa suspected of running an infostealer malware operation targeting users of an online store in California. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/ukraine-identifies-infostealer-operator-tied-to-28-000-stolen-accounts/>

02. APIs under pressure: How AI is rewriting the rules of enterprise security

The rapid growth of AI has created an explosion of APIs that will require new techniques to manage.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/resource/apis-under-pressure-how-ai-is-rewriting-the-rules-of-enterprise-security>

03. 1Password and OpenAI collaborate on secure credential access for AI coding agents

The new 1Password Environments MCP Server for Codex establishes a secure runtime environment where secrets are mounted, utilized, and then discarded after use, requiring user authentication for each access.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/1password-and-openai-collaborate-on-secure-credential-access-for-ai-coding-agents>

04. DataDome launches priority protect for virtual waiting rooms

The product enhances DataDome's existing bot detection capabilities by classifying every request in real time and applying distinct access policies for different traffic types.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/brief/datadome-launches-priority-protect-for-virtual-waiting-rooms>

05. Investigating unauthorized access to GitHub's internal repositories

If any impact is discovered, customers will be notified via established incident response and notification channels. The post Investigating unauthorized access to GitHub's internal repositories appeared first on The GitHub Blog .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://github.blog/security/investigating-unauthorized-access-to-githubs-internal-repositories/>

06. Why Policy in Amazon Bedrock AgentCore chose Cedar for securing agentic workflows

Agents have agency: they adapt and find multiple ways to solve problems. This autonomy creates a fundamental security challenge: the large language model (LLM) at the heart of the agent is non-deterministic, and its decisions can't be predicted or guaranteed in advance. It can hallucinate harmful actions with complete confidence. It's vulnerable to prompt i...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://aws.amazon.com/blogs/security/why-policy-in-amazon-bedrock-agentcore-chose-cedar-for-securing-agentic-workflows/>

07. Cyber Pros Can't Decide If AI Is a Good or a Bad Thing

There is nothing cybersecurity professionals are more excited about, and nothing they fear more, than AI.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.darkreading.com/cybersecurity-analytics/cyber-pros-ai>

08. Even Claude agrees: hole in its sandbox was real and dangerous

Another day, another AI bug silently fixed with no CVE and no public disclosure

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.theregister.com/security/2026/05/20/even-claude-agrees-hole-in-its-sandbox-was-real-and-dangerous/5243662>

09. New Mini Shai-Hulud attack targets npm ecosystem

Mini Shai-Hulud campaign hits 323 npm packages, GitHub Actions and VS Code tools.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.scworld.com/news/new-mini-shai-hulud-attack-targets-npm-ecosystem>

10. The npm Threat Landscape: Attack Surface and Mitigations (Updated May 20)

Unit 42 analyzes npm supply chain evolution post-Shai Hulud. Discover wormable malware, CI/CD persistence, multi-stage attacks and more. The post The npm Threat Landscape: Attack Surface and Mitigations (Updated May 20) appeared first on Unit 42 .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources: <https://unit42.paloaltonetworks.com/monitoring-npm-supply-chain-attacks/>

Latest Vulnerabilities (10)

01. Drupal admins rushing to patch maximum severity SQL injection vulnerability

Administrators of the Drupal open source content management platform are rushing to install an emergency patch issued today to fix a “highly critical” SQL injection vulnerability in the application’s core. While the vulnerability only affects websites that use the PostgreSQL database, there may be upstream issues with Symfony, a set of PHP packages and web...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.csoonline.com/article/4175329/drupal-admins-rushing-to-patch-maximum-severity-sql-injection-vulnerability.html>

02. WantToCry ransomware evades detection through SMB abuse, remote encryption

More than 1.5 million exposed SMB ports may be susceptible to brute force attacks.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/news/wanttocry-ransomware-evades-detection-through-smb-abuse-remote-encryption>

03. VU#980487: Local privilege escalation in Linux Kernel (Dirty Frag)

Overview A privilege escalation vulnerability, nicknamed "Dirty Frag," has been discovered in the Linux kernel versions 4.10 and later. This vulnerability is a result of chaining together two previously discovered vulnerabilities, xfrm-ESP Page-Cache Write CVE-2026-43284 and the RxRPC Page-Cache Write CVE-2026-43500...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://kb.cert.org/vuls/id/980487>

04. Hackers bypass SonicWall VPN MFA due to incomplete patching

Threat actors brute-forced VPN credentials and bypassed multi-factor authentication (MFA) on SonicWall Gen6 SSL-VPN appliances to deploy tools used in ransomware attacks. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/hackers-bypass-sonicwall-vpn-mfa-due-to-incomplete-patching/>

05. Terra Security expands platform to include network infrastructure exploitation validation

Terra's platform now allows security teams to validate vulnerabilities across web applications, AI systems, and network infrastructure from a single console.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.scworld.com/brief/terra-security-expands-platform-to-include-network-infrastructure-exploitation-validation>

06. Fake Android Apps Commit Carrier Billing Fraud for Premium Svcs.

The disguised apps use WebView automation, JavaScript injection, and OTP interception to avoid detection and complete fraudulent subscriptions.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/mobile-security/fake-android-apps-carrier-billing-fraud>

07. Discord implements end-to-end encryption for voice and video calls

The popular platform, which serves an estimated 690 million registered users, extended its open-source DAVE encryption protocol to cover all its clients, including desktop, mobile, web browsers, and gaming consoles.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.scworld.com/brief/discord-implements-end-to-end-encryption-for-voice-and-video-calls>

08. Microsoft Open-Sources RAMPART and Clarity to Secure AI Agents During Development

Microsoft has unveiled two new open-source tools called RAMPART and Clarity to assist developers in better testing the security of artificial intelligence (AI) agents. RAMPART, short for Risk Assessment and Measurement Platform for Agentic Red Teaming, functions as a Pytest-native safety and security testing framework for writing and running safety and secu...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/05/microsoft-open-sources-rampart-and.html>

09. Patch Now: Critical Flaw in OT Robot OS Gives Attackers Control

An unauthenticated attacker can exploit the command injection vulnerability to gain remote access to robotic systems, causing significant disruption to the environment.

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.darkreading.com/ics-ot-security/patch-now-critical-flaw-ot-robot-os>

10. CVE-2026-46333: Local Root Privilege Escalation and Credential Disclosure in the Linux Kernel ptrace Path

The Qualys Threat Research Unit (TRU) has discovered and published the full advisory for CVE-2026-46333, a logic flaw in the Linux kernel's `__ptrace_may_access()` function that permits an unprivileged local user to disclose sensitive files and execute arbitrary commands as root on default installations of several major distributions. The bug has resided in m...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://blog.qualys.com/vulnerabilities-threat-research/2026/05/20/cve-2026-46333-local-root-privilege-escalation-and-credential-disclosure-in-the-linux-kernel-pttrace-path>

Data Breach & Cybercrime (10)

01. Carding forum B1ack's Stash releases millions of stolen credit card records

The released data is unusually comprehensive, including full card numbers, expiration dates, CVV2 codes, cardholder names, billing addresses, email addresses, phone numbers, and IP addresses.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/carding-forum-b1acks-stash-releases-millions-of-stolen-credit-card-records>

02. Trump Mobile phone provider reportedly leaking customer data

A pair of YouTubers say their personal information, including mailing and email addresses, was leaked after they purchased the Trump Mobile T1 phone.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.scworld.com/brief/trump-mobile-phone-provider-leaking-customer-data>

03. GitHub Confirms Breach, 4K Internal Repos Stolen

Open source software giant GitHub confirmed a data breach this week involving the theft of thousands of repos. One threat actor - TeamPCP - took credit.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.darkreading.com/application-security/github-confirms-breach-4k-internal-repos-stolen>

04. Processes and Culture Top Reasons Behind Data Breaches

Government leaders revealed that, in spite of state laws meant to improve cyber hygiene, an analysis of incidents showed issues persist and visibility falls short.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.darkreading.com/cyberattacks-data-breaches/processes-and-culture-top-reasons-behind-data-breaches>

05. Grafana breach caused by missed token rotation after TanStack attack

The Grafana data breach was caused by a single GitHub workflow token that slipped through the rotation process following the TanStack npm supply-chain attack last week. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/grafana-breach-caused-by-missed-token-rotation-after-tanstack-attack/>

06. Fake malware-signing service Fox Tempest dismantled by Microsoft

The service let malware authors sign malicious files with fraudulent Microsoft-issued certificates to bypass security checks.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/news/2026/05/fake-malware-signing-service-fox-tempest-dismantled-by-microsoft>

07. Microsoft Takes Down Malware-Signing Service Behind Ransomware Attacks

Microsoft on Tuesday said it disrupted a malware-signing-as-a-service (MSaaS) operation that weaponized the company's Artifact Signing system to deliver malicious code and conduct ransomware and other attacks, compromising thousands of machines and networks across the world. The tech giant attributed the activity to a threat actor it calls Fox Tempest, which...

Why it matters: Ransomware operations combine disruption with extortion, making recovery speed and data-resilience core business risks.

Recommendation: Verify offline backups, test restores, harden remote access, and review segmentation to limit lateral movement.

Sources: <https://thehackernews.com/2026/05/microsoft-takes-down-malware-signing.html>

08. Identity Alone Isn't Enough: Why Device Security Has to Share the Load

Identity checks alone can't stop attackers using stolen session tokens and compromised devices. Specops Software outlines why Zero Trust strategies increasingly depend on continuous device verification. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/identity-alone-isnt-enough-why-device-security-has-to-share-the-load/>

09. 1Password Teams With OpenAI to Stop AI Coding Agents From Leaking Credentials

1Password says AI coding agents should never hold persistent secrets, introducing a just-in-time credential model for OpenAI Codex designed to keep credentials out of prompts, code repositories, and model context. The post 1Password Teams With OpenAI to Stop AI Coding Agents From Leaking Credentials appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/1password-teams-with-openai-to-stop-ai-coding-agents-from-leaking-credentials/>

10. GitHub Breached - Employee Device Hack Led to Exfiltration of 3,800+ Internal Repos

GitHub on Tuesday said it's investigating unauthorized access to its internal repositories after the notorious threat actor known as TeamPCP listed the platform's source code and internal organizations for sale on a cybercrime forum. "While we currently have no evidence of impact to customer information stored outside of GitHub's internal repositories (such...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/05/github-investigating-teampcp-claimed.html>